CIA Part 1 – 100 Hard Exam Questions

Governance, Risk, Controls, Ethics, IT & QAIP

CIA Study Prep

October 17, 2026

Instructions

Each question slide is followed by a separate answer/explanation slide.

Do NOT advance until you have selected an answer.

Questions are written at or above real exam difficulty.

Distractors are designed to be plausible; read every word.

Q1

Question: The chief audit executive (CAE) of a mid-sized financial services firm has been asked by the CEO to take operational responsibility for implementing a new enterprise-wide fraud risk management program, including designing the controls, selecting the fraud analytics software, and chairing the cross-functional fraud governance committee. The CAE's staff has deep fraud expertise, and the board has expressed strong support for the initiative. Which course of action BEST preserves conformance with the IIA International Standards while still allowing the organization to benefit from the CAE's expertise?

A. Accept the role because the board supports it and the CAE has the requisite expertise; disclose the arrangement in the next audit report.

B. Decline any involvement because assuming operational responsibility always impairs independence, and recommend an external consultant.

C. Accept an advisory role only, ensuring management retains ownership of design, implementation, and decisions, and avoid auditing the program until objectivity is no longer impaired.

D. Accept the role but delegate the actual auditing of the fraud program to a subordinate so the CAE's objectivity is preserved.

Q1 – Answer & Explanation

Correct Answer: C

Why: Standards 1130 and the Code require internal auditors to avoid assuming management responsibilities. An advisory-only role preserves objectivity; auditing a program the CAE designed/implemented would create a self-review threat (Standard 1130.A1).

A wrong: Board support does not cure the impairment; disclosure does not eliminate self-review.

B wrong: Total abstention is overly restrictive; advisory/consulting support is permitted.

D wrong: Delegating the audit does not cure the CAE's self-review threat.

Q2

Question: During an engagement at a multinational manufacturer, an internal auditor discovers that a senior vice president (SVP) has been directing purchase orders to a supplier owned by the SVP's spouse, and that the SVP also approved the related invoices. The auditor's draft report contains this finding. Before the report is issued, the CAE is told by the CEO that the SVP is a "key rainmaker" and that including the finding "would be politically damaging." The CEO asks the CAE to remove the finding and instead include a general recommendation to "strengthen procurement controls." Which action is MOST consistent with the IIA Code of Ethics and Standards?

A. Remove the specific finding but keep the general recommendation, since the CEO has legitimate business reasons.

B. Keep the finding, and if the CEO persists, escalate the matter to the audit committee or board.

C. Remove the finding but document the CEO's request in a memo to file for future reference.

D. Ask the SVP to self-disclose to the board before the report is issued.

Q2 – Answer & Explanation

Correct Answer: B

Why: Integrity and Objectivity (Code) and Standard 2600 require reporting significant risk/control issues and escalating unresolved matters to the board. Suppressing a valid finding misrepresents facts.

A wrong: Removing a valid finding because of political pressure violates Integrity.

C wrong: Documenting the request does not cure the suppression.

D wrong: The auditor cannot delegate the reporting obligation to the SVP.

Q3

Question: An internal audit team is testing the operating effectiveness of a three-way match control in a high-volume accounts payable environment. The control is automated within the ERP, and IT has provided a system-generated report showing that 99.7% of invoices matched purchase orders and receiving reports during the year. The team has limited IT audit skills. Which approach provides the MOST persuasive evidence of operating effectiveness while remaining consistent with the Standards?

A. Rely on the IT-generated report, because it covers the full population and is therefore more reliable than sampling.

B. Re-perform the three-way match manually on a sample of invoices and also test the automated control's configuration and exception handling.

C. Interview the accounts payable manager and obtain a management representation letter confirming the control operates effectively.

D. Reduce testing because the control is automated; automated controls do not require substantive testing.

Q3 – Answer & Explanation

Correct Answer: B

Why: Standard 2300 requires sufficient, reliable evidence. Automated controls need both tests of general IT controls/configuration and substantive testing of outputs/exceptions. Re-performance and configuration testing provide strong evidence.

A wrong: An IT-generated report is internal evidence and must be validated (completeness/accuracy of the report logic).

C wrong: Inquiry and representations alone are weak evidence.

D wrong: Automated controls still require testing; reliance is not automatic.

Q4

Question: The CAE is reviewing the annual risk-based audit plan. Management has identified a new strategic initiative involving a complex joint venture in a foreign jurisdiction with limited regulatory oversight and a history of corruption. The joint venture is expected to represent 25% of consolidated revenue within two years. Management has not yet performed a fraud risk assessment for the venture, and no internal audit work has been done in that jurisdiction. Which action is MOST appropriate for the CAE?

A. Exclude the joint venture from the plan until management completes its own fraud risk assessment.

B. Include the joint venture in the audit plan with priority, considering corruption/fraud risk, and coordinate with compliance and legal.

C. Defer the engagement because internal audit lacks jurisdictional expertise and the venture is not yet material.

D. Assign the engagement to the least experienced staff to build their international experience.

Q4 – Answer & Explanation

Correct Answer: B

Why: Standard 2010 requires a risk-based plan; Standard 1210.A2 requires assessing fraud risk. High corruption risk and materiality warrant priority coverage, with coordination to leverage other assurance providers (Standard 2050).

A wrong: Waiting for management defeats the purpose of independent assurance.

C wrong: Lack of expertise can be addressed through training/specialists (Standard 1210); deferral ignores risk.

D wrong: Assigning inexperienced staff to a high-risk engagement violates due professional care (Standard 1220).

Q5

Question: An auditor is evaluating the design of a control over the completeness of revenue recognition. The control requires that shipping documents be matched to sales invoices before revenue is recorded. The auditor observes that the control operates as described for domestic sales but that export sales are recorded based on a bill of lading prepared by a third-party freight forwarder, and no matching to invoices occurs for those sales. Export sales represent 30% of revenue. Which conclusion is MOST appropriate?

A. The control is effective because it operates for the majority of transactions (domestic sales).

B. The control is deficient in design because it does not address a significant class of transactions (export sales).

C. The control is effective because third-party freight forwarders are independent.

D. The control should be tested only for domestic sales, and export sales should be excluded from the engagement scope.

Q5 – Answer & Explanation

Correct Answer: B

Why: A control must address the risk for all relevant transaction classes. A design gap for 30% of revenue (export sales) is a significant deficiency in design (Standard 2130/2201).

A wrong: Partial coverage does not make the control effective for the uncovered population.

C wrong: Third-party independence does not substitute for the missing control.

D wrong: Excluding material transactions from scope is improper and would violate Standards 2220/2300.

Q6

Question: During an engagement, an internal auditor learns that the organization's external auditor is planning to rely on the same key control (a monthly reconciliation of intercompany balances) that the internal auditor is testing. The external auditor asks the internal auditor to share detailed workpapers, including a schedule of unreconciled differences that management has not yet resolved. Which response is MOST appropriate?

A. Share the workpapers freely because external audit coordination is required by Standard 2050.

B. Coordinate with the external auditor, but obtain CAE approval and ensure confidentiality/independence requirements are met before sharing.

C. Refuse all sharing because internal audit workpapers are strictly confidential.

D. Share only the favorable results and withhold the unreconciled differences.

Q6 – Answer & Explanation

Correct Answer: B

Why: Standard 2050 encourages coordination, but Standard 2330.A2 (confidentiality) and the CAE's authority govern workpaper sharing. Approval and confidentiality safeguards are required.

A wrong: Unrestricted sharing may breach confidentiality and organizational policy.

C wrong: Refusing all sharing defeats coordination and is overly restrictive.

D wrong: Selective sharing that hides unresolved differences is misleading and unethical.

Q7

Question: The audit committee has asked the CAE to assess whether the organization's governance processes are effective. The organization has a dominant CEO who also chairs the board, a small number of independent directors, and no separate risk committee. The audit committee itself has two members with prior business relationships with the CEO. Which combination of factors is MOST likely to indicate a governance weakness that internal audit should highlight?

A. Combined CEO/chair role, limited independence on the board and audit committee, and absence of a risk committee.

B. The existence of an audit committee and a written code of conduct.

C. The CEO's long tenure and the organization's profitability.

D. The presence of an internal audit function and an external auditor.

Q7 – Answer & Explanation

Correct Answer: A

Why: Standard 2110 requires assessing governance. CEO/chair duality, insufficient independence, and lack of a risk committee are classic governance weaknesses.

B wrong: These are positive governance features.

C wrong: Tenure and profitability alone are not governance weaknesses.

D wrong: These are structural strengths, not weaknesses.

Q8

Question: An internal auditor is performing a follow-up engagement on a prior recommendation to implement mandatory vacation policies for employees with access to cash. Management reports that the policy has been implemented, but the auditor finds that two employees in the cash office have not taken vacation in 18 months and that their duties have not been rotated. Management explains that these employees are "trusted" and that the policy is "generally applied." Which conclusion is MOST appropriate?

A. The recommendation is implemented because a policy exists and is generally applied.

B. The recommendation is not fully implemented; the exceptions represent a control weakness and should be reported.

C. The recommendation should be closed because management has provided an explanation.

D. The auditor should extend the follow-up period by 12 months without reporting the exceptions.

Q8 – Answer & Explanation

Correct Answer: B

Why: Standard 2500 requires follow-up to confirm implementation. Exceptions (no vacation/rotation for cash-access employees) indicate the control is not operating as intended.

A wrong: A policy on paper is not implementation; "generally applied" is not adequate.

C wrong: Management explanation does not close the finding.

D wrong: Delaying without reporting hides a control weakness.

Q9

Question: The CAE is evaluating whether the internal audit activity's quality assurance and improvement program (QAIP) is conforming with the Standards. The activity has an internal assessment process, but the last external quality assessment was performed six years ago. The CAE argues that the external assessment is not required because the internal assessments have identified no significant issues. Which statement is MOST accurate?

A. The CAE is correct; external assessments are optional if internal assessments are clean.

B. The CAE is incorrect; Standard 1312 requires an external assessment at least every five years.

C. The CAE is correct; external assessments are required only for public companies.

D. The CAE is incorrect; external assessments are required annually.

Q9 – Answer & Explanation

Correct Answer: B

Why: Standard 1312 requires an external assessment at least once every five years by a qualified, independent assessor.

A wrong: Internal assessments do not substitute for the required external assessment.

C wrong: The requirement applies to all internal audit activities conforming with the Standards.

D wrong: Annual external assessment is not required.

Q10

Question: An auditor is testing the completeness of recorded accounts payable at year-end. The auditor selects a sample of receiving reports from the last two weeks of the year and traces them to the accounts payable subsidiary ledger. Several receiving reports have no corresponding payable recorded until the following year. Management explains that the goods were "in transit" and that the related invoices had not been received. Which conclusion is MOST appropriate?

A. The payables are complete because invoices had not been received.

B. The payables are likely understated; goods received before year-end should be recorded as liabilities even if invoices are not yet received.

C. The payables are overstated because the goods were in transit.

D. The auditor should ignore the exceptions because management provided an explanation.

Q10 – Answer & Explanation

Correct Answer: B

Why: Completeness testing from receiving reports to the ledger tests whether all liabilities are recorded. Goods received before year-end create a liability (accrual) even without an invoice; failure to record understates payables.

A wrong: Lack of invoice does not eliminate the liability.

C wrong: The issue is understatement, not overstatement.

D wrong: Management explanations must be corroborated and do not eliminate valid exceptions.

Q11

Question: An internal auditor is assigned to audit the treasury function. The auditor's sibling is a treasury analyst responsible for reconciling bank accounts. The auditor discloses the relationship to the CAE, who states that the sibling's role is "limited" and that the auditor can proceed as long as the sibling is not interviewed. Which action is MOST appropriate?

A. Proceed with the audit as directed by the CAE, avoiding interviews with the sibling.

B. Decline the assignment and request reassignment, because the close relationship impairs objectivity regardless of interview scope.

C. Proceed but have the sibling's work reviewed by another auditor.

D. Proceed and document the relationship in the workpapers only.

Q11 – Answer & Explanation

Correct Answer: B

Why: Standard 1130 requires objectivity. A close family member in the audited function creates a familiarity/self-interest threat that cannot be cured by avoiding interviews or reviewing work. Reassignment is required.

A wrong: Avoiding interviews does not remove the impairment.

C wrong: Review by another auditor does not cure the auditor's bias.

D wrong: Documentation alone does not restore objectivity.

Q12

Question: The CAE is asked to provide consulting services to management on the design of a new whistleblower hotline. The CAE has previous experience designing hotlines and believes internal audit can add value. Management has not yet selected a vendor. Which statement BEST describes the CAE's permissible role?

A. Internal audit may design, implement, and operate the hotline as long as the CAE discloses the involvement.

B. Internal audit may provide advice and recommendations, but management must retain ownership and decision-making authority.

C. Internal audit may not provide any consulting services on the hotline.

D. Internal audit may operate the hotline only if the audit committee approves.

Q12 – Answer & Explanation

Correct Answer: B

Why: Consulting is permitted (Standards 1000.A1/Consulting) provided internal audit does not assume management responsibility. Advising on design is acceptable; owning/operating the hotline would impair objectivity for later assurance.

A wrong: Designing, implementing, and operating would create management responsibility and self-review.

C wrong: Total prohibition is incorrect; advisory services are allowed.

D wrong: Operating the hotline is a management function regardless of approval.

Q13

Question: An auditor is evaluating the organization's fraud risk assessment process. Management's assessment identifies only "asset misappropriation by junior staff" as a fraud risk and does not address management override, financial statement fraud, or corruption. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because it addresses the most common fraud type.

B. The fraud risk assessment is deficient because it omits significant fraud risks, including management override, financial reporting fraud, and corruption.

C. The fraud risk assessment is adequate because junior staff represent the largest employee group.

D. The auditor should not evaluate management's fraud risk assessment; that is the external auditor's responsibility.

Q13 – Answer & Explanation

Correct Answer: B

Why: Standard 1210.A2/2200 requires internal audit to consider fraud risk, including management override, fraudulent reporting, and corruption. An assessment that omits these is incomplete.

A wrong: Frequency is not the only factor; severity and management override are critical.

C wrong: Headcount is not a basis for omitting significant risks.

D wrong: Internal audit is responsible for assessing fraud risk.

Q14

Question: During fieldwork, an auditor finds that the organization has been capitalizing routine maintenance costs as fixed assets, which increases profitability and asset values. Management states that the practice is "industry norm" and that the amounts are "not large." The auditor estimates that the impact is 8% of pre-tax income and that the practice has occurred for three years. Which action is MOST appropriate?

A. Accept management's explanation because the practice is common in the industry.

B. Document the finding, assess materiality and fraud indicators, and report through appropriate channels.

C. Report the finding only if the amount exceeds 10% of pre-tax income.

D. Refer the matter to the external auditor and take no further action.

Q14 – Answer & Explanation

Correct Answer: B

Why: Capitalizing routine maintenance is a potential accounting irregularity/fraud indicator. 8% of pre-tax income over three years is likely material and may indicate intentional misstatement. Report and escalate.

A wrong: Industry practice does not justify non-compliance with accounting standards.

C wrong: Materiality is not a rigid 10% threshold; qualitative factors matter.

D wrong: Internal audit must report findings, not simply refer.

Q15

Question: The audit committee asks the CAE whether the internal audit activity has sufficient resources to execute the approved risk-based plan. The CAE has 12 auditors, a flat budget, and a plan that requires specialized IT security and data analytics skills that the team currently lacks. Which response is MOST appropriate?

A. State that resources are adequate because headcount has not changed.

B. Explain that resources are insufficient for the plan's scope and recommend acquiring specialized skills or adjusting the plan/scope.

C. Reduce the audit plan silently to match current skills without informing the committee.

D. Outsource the entire internal audit function to a third party.

Q15 – Answer & Explanation

Correct Answer: B

Why: Standard 2030 requires the CAE to assess resource adequacy against the plan and communicate limitations to the board/audit committee. Specialized skills are needed for IT/analytics coverage.

A wrong: Headcount alone does not demonstrate adequacy.

C wrong: Unilaterally reducing the plan without disclosure violates Standards 2010/2020/2030.

D wrong: Full outsourcing is an overreaction and not required.

Q16

Question: An auditor is testing the effectiveness of a control that requires dual authorization for wire transfers above $100,000. The auditor selects a sample of 60 wires and finds that 4 wires (6.7%) were authorized by only one person. The tolerable deviation rate is 5%. Management states that the exceptions were "emergencies" and that all wires were legitimate. Which conclusion is MOST appropriate?

A. The control is effective because the wires were legitimate.

B. The control is not operating effectively; the deviation rate exceeds the tolerable rate and should be reported.

C. The control is effective because 93.3% of wires were properly authorized.

D. The auditor should ignore the exceptions because management provided an explanation.

Q16 – Answer & Explanation

Correct Answer: B

Why: When the sample deviation rate exceeds the tolerable rate, the control cannot be relied upon as operating effectively; expand testing or report a deficiency (Standard 2300).

A wrong: Legitimacy of the wires does not cure the authorization control failure.

C wrong: The control requires dual authorization for all wires; 6.7% failure is significant.

D wrong: Management explanations do not eliminate deviations.

Q17

Question: The CAE reports functionally to the audit committee and administratively to the CFO. The CFO has asked the CAE to delay reporting a significant internal control deficiency in the finance department until after the CFO's upcoming performance review. Which action is MOST appropriate?

A. Delay the report as requested to maintain a good working relationship with the CFO.

B. Report the deficiency promptly and escalate the CFO's request to the audit committee.

C. Report the deficiency to the external auditor instead of the audit committee.

D. Document the request and delay the report by one quarter.

Q17 – Answer & Explanation

Correct Answer: B

Why: Standard 2600 requires prompt reporting of significant issues to the board/audit committee. Administrative reporting to the CFO does not permit suppression, and the request itself is a governance concern.

A wrong: Delaying significant findings violates the Standards.

C wrong: Reporting to the external auditor does not replace board reporting.

D wrong: Documentation does not justify delay.

Q18

Question: An auditor is evaluating the organization's IT general controls over program changes. The auditor finds that developers have direct access to the production environment and that changes are sometimes moved to production without independent testing or approval. The auditor also finds that the IT director reviews a monthly change log after the fact. Which conclusion is MOST appropriate?

A. IT general controls are effective because the IT director reviews the change log monthly.

B. IT general controls are deficient; direct developer access and lack of independent testing/approval are significant weaknesses.

C. IT general controls are effective because developers are trusted employees.

D. The auditor should not assess IT controls; that is the role of the IT department.

Q18 – Answer & Explanation

Correct Answer: B

Why: Proper change management requires segregation of development from production, independent testing, and approval before deployment. A post-hoc log review does not mitigate these design weaknesses.

A wrong: Detective review does not compensate for missing preventive controls.

C wrong: Trust is not a control.

D wrong: Internal audit must assess IT controls relevant to the engagement.

Q19

Question: An auditor is asked to perform an engagement at a subsidiary located in a country where facilitating payments ("grease payments") are common and legal locally, but are prohibited by the organization's code of conduct and by the organization's home-country law. The subsidiary manager explains that such payments are "necessary to do business" and are "small." Which action is MOST appropriate for the auditor?

A. Accept the practice because it is legal in the local country.

B. Treat the payments as potential violations of the organization's code and applicable law, investigate, and report.

C. Ignore the payments because they are small and routine.

D. Advise management to reclassify the payments as "consulting fees."

Q19 – Answer & Explanation

Correct Answer: B

Why: The organization's code and home-country law prohibit facilitating payments. Internal audit must assess compliance and report potential legal/code violations (Standard 2100/2400, Integrity).

A wrong: Local legality does not override the organization's code or home-country law.

C wrong: "Small and routine" does not exempt prohibited payments.

D wrong: Reclassifying to conceal payments is fraudulent.

Q20

Question: The CAE is developing the internal audit activity's risk-based plan. The organization has recently acquired a competitor, resulting in new systems, new markets, and a 40% increase in headcount. Management's risk register has not been updated since the acquisition. Which action is MOST appropriate for the CAE?

A. Use the existing risk register unchanged because it was approved by management.

B. Update the risk assessment to reflect acquisition-related risks and revise the audit plan accordingly.

C. Defer planning until management updates the risk register.

D. Focus the audit plan only on the pre-acquisition business to avoid complexity.

Q20 – Answer & Explanation

Correct Answer: B

Why: Standard 2010 requires a risk-based plan. An acquisition materially changes the risk profile; the CAE must update the risk assessment and plan.

A wrong: Relying on a stale register ignores new risks.

C wrong: Deferring leaves the organization without assurance.

D wrong: Excluding the acquired business ignores significant risk.

Q21

Question: An auditor is evaluating the organization's risk appetite and tolerance. The board has stated that the organization has "low tolerance for compliance risk" but management has consistently accepted compliance exceptions to meet sales targets, and no disciplinary action has been taken. Which conclusion is MOST appropriate?

A. The risk appetite and tolerance are aligned because the board has a stated policy.

B. There is a disconnect between the stated risk appetite and actual behavior, indicating a weak risk culture.

C. Compliance risk is not relevant to internal audit.

D. The auditor should ignore the disconnect because management is responsible for risk.

Q21 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be reflected in behavior and enforcement, not just statements. Accepting exceptions without consequences signals a weak risk culture and misalignment (Standard 2110/2120).

A wrong: A stated policy without enforcement is not alignment.

C wrong: Compliance risk is a core internal audit area.

D wrong: Internal audit must assess and report on risk culture and governance.

Q22

Question: An auditor is testing a sample of journal entries for management override. The auditor finds several large manual entries posted at year-end by the controller, with descriptions such as "reclass" and "true-up," lacking supporting documentation. The controller states that the entries were "normal year-end adjustments" and that supporting schedules are "in the controller's office." Which action is MOST appropriate?

A. Accept the controller's explanation because the entries are described as normal adjustments.

B. Obtain the supporting schedules, inspect them, and investigate the entries further; if support is inadequate, report as a deficiency.

C. Ignore the entries because they were posted by the controller.

D. Report the controller to external authorities immediately.

Q22 – Answer & Explanation

Correct Answer: B

Why: Manual year-end entries by senior management are a high fraud risk area. The auditor must obtain and inspect support and investigate; lack of support is a significant deficiency.

A wrong: Labels do not substitute for evidence.

C wrong: Authority does not exempt entries from testing.

D wrong: External reporting is premature without investigation.

Q23

Question: The audit committee has asked the CAE to assess whether the organization's code of conduct is effective. The CAE finds that the code is published on the intranet, employees sign an annual acknowledgment, but there is no training, no hotline, and no disciplinary process for violations. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is published and acknowledged annually.

B. The code of conduct is not fully effective; training, reporting mechanisms, and enforcement are essential elements.

C. The code of conduct is effective because employees signed acknowledgments.

D. The code of conduct is outside the scope of internal audit.

Q23 – Answer & Explanation

Correct Answer: B

Why: An effective ethics program includes communication/training, reporting channels, and enforcement. Publication and signatures alone are insufficient (Standard 2110).

A wrong: Publication without training/enforcement is weak.

C wrong: Acknowledgments do not demonstrate understanding or compliance.

D wrong: Internal audit assesses ethics and governance.

Q24

Question: An internal auditor is evaluating a proposed control that would require the same clerk to both prepare and approve petty cash reimbursements because of staff shortages. Management argues that the clerk is "experienced and honest." Which response is MOST appropriate?

A. Approve the control because the clerk is experienced and honest.

B. Identify the segregation of duties weakness and recommend a compensating control or alternative staffing arrangement.

C. Ignore the issue because petty cash is immaterial.

D. Recommend eliminating petty cash entirely without further analysis.

Q24 – Answer & Explanation

Correct Answer: B

Why: Combining preparation and approval of petty cash reimbursements creates a fraud opportunity. Recommend segregation or compensating controls (Standard 2130).

A wrong: Honesty is not a control.

C wrong: Immateriality does not eliminate fraud risk.

D wrong: Elimination may be impractical; analyze first.

Q25

Question: The CAE is assessing the internal audit activity's conformance with the Standards. The CAE finds that engagements are planned, performed, and reported consistently with the Standards, but that the activity has no documented QAIP, no ongoing internal assessments, and no periodic internal assessments. Which statement is MOST accurate?

A. The activity conforms because engagements themselves follow the Standards.

B. The activity does not fully conform; Standards 1300/1310/1311 require a QAIP with ongoing and periodic internal assessments.

C. The QAIP is optional for small audit activities.

D. The QAIP is only required for external assessments.

Q25 – Answer & Explanation

Correct Answer: B

Why: Standards 1300-1312 require a QAIP covering all aspects of the internal audit activity, including ongoing and periodic internal assessments, and external assessments every five years.

A wrong: Engagement-level conformance does not replace the QAIP.

C wrong: The QAIP is required for all internal audit activities.

D wrong: Internal assessments are part of the QAIP.

Q26

Question: An auditor is evaluating the organization's use of a cloud service provider (CSP) for a critical financial application. The CSP has provided a SOC 2 Type II report covering a period ending nine months ago. The report includes complementary user entity controls (CUECs) that the organization has not implemented. Which conclusion is MOST appropriate?

A. The SOC 2 report provides sufficient assurance because it is a Type II report.

B. The organization cannot rely solely on the SOC 2 report; the period is stale and CUECs are not implemented.

C. The SOC 2 report is irrelevant because it is issued by the CSP.

D. The auditor should ignore the CUECs because they are the CSP's responsibility.

Q26 – Answer & Explanation

Correct Answer: B

Why: SOC 2 Type II covers a period; a nine-month-old report may not reflect current controls, and CUECs are the user entity's responsibility. Reliance requires evaluating both.

A wrong: Type II is useful but not sufficient without considering period and CUECs.

C wrong: SOC reports are relevant evidence.

D wrong: CUECs must be implemented by the organization.

Q27

Question: An auditor is assessing the organization's risk management process. Management's risk register lists 25 risks, all rated "low" or "medium," and no risks are rated "high." The auditor knows the organization operates in a highly regulated industry, has significant debt covenants, and recently lost a major customer. Which conclusion is MOST appropriate?

A. The risk register is adequate because management has identified 25 risks.

B. The risk register is likely incomplete or misrated; the auditor should challenge the assessment and recommend reassessment.

C. The auditor should accept the register because risk assessment is management's responsibility.

D. The auditor should add the missing risks to the register personally.

Q27 – Answer & Explanation

Correct Answer: B

Why: Standard 2120 requires internal audit to assess risk management. A register with no high risks in a high-risk environment is implausible; the auditor should challenge and recommend reassessment.

A wrong: Count is not quality.

C wrong: Internal audit must evaluate the adequacy of risk management.

D wrong: Internal audit should not take over management's risk register.

Q28

Question: The CAE is evaluating whether to rely on the work of the organization's compliance function for an engagement on anti-money-laundering (AML) controls. The compliance function has qualified staff, reports to the chief risk officer, and has performed extensive AML testing. However, the compliance function also designed the AML controls it tested. Which factor is MOST important in the CAE's reliance decision?

A. The compliance function's qualifications and testing extent.

B. The compliance function's objectivity, including its role in designing the controls it tested.

C. The compliance function's reporting line to the chief risk officer.

D. The compliance function's budget.

Q28 – Answer & Explanation

Correct Answer: B

Why: Standard 2050 requires evaluating the objectivity and competence of other assurance providers. A self-review threat (designing and testing the same controls) impairs objectivity and limits reliance.

A wrong: Competence alone is insufficient without objectivity.

C wrong: Reporting line is a factor but not as critical as objectivity/self-review.

D wrong: Budget is not a reliance criterion.

Q29

Question: An auditor is testing the organization's compliance with debt covenants. The auditor finds that the organization's debt-to-equity ratio is 2.8:1, while the covenant requires a maximum of 3.0:1. Management has proposed a "pro forma" adjustment that would reduce the ratio to 2.7:1 by excluding a recent acquisition. The covenant agreement does not permit pro forma adjustments. Which conclusion is MOST appropriate?

A. The organization is in compliance because the pro forma ratio is below the covenant limit.

B. The organization is in compliance because the actual ratio is below the covenant limit, and the pro forma adjustment is unnecessary.

C. The organization may be in violation if the covenant calculation excludes the acquisition; the auditor should verify the covenant definition and report accordingly.

D. The auditor should accept management's pro forma adjustment because acquisitions are one-time events.

Q29 – Answer & Explanation

Correct Answer: C

Why: Covenant compliance depends on the contractual definition. If the acquisition must be included and the ratio exceeds the limit, there is a violation. The auditor must verify the covenant terms and report.

A wrong: Pro forma adjustments not permitted by the covenant are invalid.

B wrong: The actual ratio may exceed the limit depending on the definition; the auditor must verify.

D wrong: Unilateral pro forma adjustments are not acceptable.

Q30

Question: The CAE is asked by the CEO to "take a fresh look" at the organization's procurement process and to "recommend improvements." The CEO states that the engagement is a consulting engagement, not an audit, and that no report to the audit committee is necessary. Which statement is MOST accurate?

A. Because it is consulting, no documentation or communication is required.

B. Consulting engagements still require documentation, and significant findings should be communicated to the board/audit committee per the charter and Standards.

C. Consulting engagements are prohibited for internal audit.

D. The CAE should refuse the engagement because it is requested by the CEO.

Q30 – Answer & Explanation

Correct Answer: B

Why: Consulting engagements must be documented and communicated per Standards 2330/2400 and the charter. Significant risk/control issues must reach governance.

A wrong: All engagements require documentation.

C wrong: Consulting is permitted.

D wrong: CEO requests are acceptable if within the charter and planned appropriately.

Q31

Question: An auditor is assessing the organization's use of data analytics for continuous monitoring. The organization has implemented a tool that flags all invoices paid outside normal terms. The tool has generated 5,000 alerts in the past quarter, and no one has reviewed them. Which conclusion is MOST appropriate?

A. The continuous monitoring control is effective because the tool is generating alerts.

B. The continuous monitoring control is not effective because alerts are not reviewed and acted upon.

C. The tool should be turned off because it generates too many alerts.

D. The auditor should review all 5,000 alerts personally.

Q31 – Answer & Explanation

Correct Answer: B

Why: A monitoring control is only effective if exceptions are investigated and resolved. Unreviewed alerts indicate the control is not operating.

A wrong: Generation without review is not effectiveness.

C wrong: Turning off the tool removes monitoring; the issue is follow-up.

D wrong: Internal audit may sample/test, but management must operate the control.

Q32

Question: An auditor is evaluating a whistleblower hotline. The hotline is managed by the HR director, who reports to the CEO. Employees can report anonymously, but the HR director reviews all reports before they are escalated and has discretion to close them. Which conclusion is MOST appropriate?

A. The hotline is effective because it allows anonymous reporting.

B. The hotline has a significant design weakness because the HR director (reporting to the CEO) has discretion to suppress reports.

C. The hotline is effective because HR is independent of management.

D. The hotline design is outside the scope of internal audit.

Q32 – Answer & Explanation

Correct Answer: B

Why: An effective whistleblower hotline should be independent, with reports reaching the audit committee/board. HR reporting to the CEO with discretion to close reports creates a suppression risk.

A wrong: Anonymity is not enough; independence and escalation matter.

C wrong: HR is not independent of management.

D wrong: Internal audit assesses ethics/governance processes.

Q33

Question: An auditor is performing an engagement on the organization's vendor master file. The auditor finds that 15 vendors have addresses matching employee home addresses, and 5 of those vendors were added by the same accounts payable clerk. The clerk states that the vendors are "legitimate contractors." Which action is MOST appropriate?

A. Accept the clerk's explanation because the vendors are described as contractors.

B. Investigate the vendors further, treat the findings as potential fraud indicators, and report through appropriate channels.

C. Remove the vendors from the master file personally.

D. Ignore the findings because vendor addresses can change.

Q33 – Answer & Explanation

Correct Answer: B

Why: Vendors with employee addresses added by the same clerk are classic ghost-vendor/kickback red flags. Investigate and report; do not alter records.

A wrong: Labels do not explain the red flags.

C wrong: Internal audit should not make management changes.

D wrong: Ignoring fraud indicators is improper.

Q34

Question: The CAE is asked to evaluate whether the organization's board is effective. The board meets quarterly, receives a 200-page pre-read two days before each meeting, has no independent directors, and relies entirely on management's presentations. Which conclusion is MOST appropriate?

A. The board is effective because it meets quarterly.

B. The board is likely ineffective; lack of independence, late/overwhelming information, and reliance on management impair oversight.

C. The board is effective because it receives extensive documentation.

D. The board's effectiveness is not an internal audit concern.

Q34 – Answer & Explanation

Correct Answer: B

Why: Effective board oversight requires independence, timely/concise information, and the ability to challenge management. The described practices indicate governance weakness.

A wrong: Meeting frequency alone is not effectiveness.

C wrong: Volume and timing impair, not enhance, oversight.

D wrong: Internal audit assesses governance (Standard 2110).

Q35

Question: An auditor is testing the completeness of revenue. The auditor traces a sample of shipping documents to sales invoices and finds that 8% of shipments were not invoiced until the following month. Management states that the shipments were "held for customer pickup" and that revenue was recorded when the customer picked up the goods. Which conclusion is MOST appropriate?

A. Revenue is complete because revenue was recorded upon customer pickup.

B. Revenue may be understated; if control transferred at shipment, revenue should have been recorded earlier.

C. Revenue is overstated because invoices were issued late.

D. The auditor should ignore the exceptions because management provided an explanation.

Q35 – Answer & Explanation

Correct Answer: B

Why: Revenue recognition depends on transfer of control. If control transferred at shipment, recording at pickup understates revenue in the period.

A wrong: Pickup may not be the correct recognition point.

C wrong: Late invoicing may indicate understatement, not overstatement.

D wrong: Explanations must be corroborated.

Q36

Question: An auditor is assessing the organization's third-party risk management. The organization uses 40 critical vendors, but due diligence was performed only for the top 5 vendors. Vendor contracts do not include audit rights or security requirements. Which conclusion is MOST appropriate?

A. Third-party risk management is adequate because the top 5 vendors were reviewed.

B. Third-party risk management is deficient; critical vendors lack due diligence, audit rights, and security requirements.

C. Third-party risk is not relevant to internal audit.

D. The organization should terminate all 40 vendors immediately.

Q36 – Answer & Explanation

Correct Answer: B

Why: Critical vendors require risk-based due diligence, contractual audit rights, and security requirements. Coverage of only 5 of 40 is insufficient.

A wrong: Partial coverage leaves significant risk unmanaged.

C wrong: Third-party risk is a key internal audit area.

D wrong: Termination is an overreaction; remediation is needed.

Q37

Question: The CAE is evaluating whether an engagement should be performed as assurance or consulting. Management has asked internal audit to "help design" a new revenue recognition process and to "provide ongoing advice" during implementation. Which statement is MOST accurate?

A. This is an assurance engagement because revenue recognition is a financial reporting area.

B. This is a consulting engagement; internal audit may advise but must not assume management responsibility, and later assurance may be impaired.

C. Internal audit may design the process and later audit it as assurance.

D. Internal audit should refuse any involvement in revenue recognition.

Q37 – Answer & Explanation

Correct Answer: B

Why: Providing advice during design is consulting. Internal audit must not take management responsibility, and self-review may preclude later assurance (Standard 1130).

A wrong: The nature is advisory, not assurance.

C wrong: Designing then auditing creates a self-review threat.

D wrong: Advisory involvement is permitted with safeguards.

Q38

Question: An auditor is testing the organization's physical inventory count. The auditor observes that the warehouse manager counts inventory, records the counts, and also approves the count sheets, with no independent verification. The auditor also notes that the warehouse manager has access to the inventory system to adjust balances. Which conclusion is MOST appropriate?

A. Inventory controls are effective because the warehouse manager is knowledgeable.

B. Inventory controls are deficient; combining counting, recording, approving, and system adjustment creates a significant segregation-of-duties weakness.

C. Inventory controls are effective because the manager is a senior employee.

D. The auditor should not assess inventory controls because inventory is an operational matter.

Q38 – Answer & Explanation

Correct Answer: B

Why: Combining custody, recording, authorization, and system adjustment defeats segregation of duties and creates a significant fraud/error risk.

A wrong: Knowledge does not compensate for lack of segregation.

C wrong: Seniority is not a control.

D wrong: Inventory is a core financial/operational audit area.

Q39

Question: The CAE is asked by the audit committee to assess whether the organization's risk management framework is effective. The organization has a risk register, a risk committee, and a chief risk officer, but risk assessments are performed annually only, risks are not linked to strategy, and no key risk indicators are monitored. Which conclusion is MOST appropriate?

A. The risk management framework is effective because it has a register, committee, and CRO.

B. The risk management framework is partially effective but has significant gaps; it is not continuous, not strategy-linked, and lacks KRIs.

C. The risk management framework is effective because annual assessments are sufficient.

D. Risk management is outside the scope of internal audit.

Q39 – Answer & Explanation

Correct Answer: B

Why: Effective ERM is continuous, linked to strategy, and monitored via KRIs. Structural elements alone do not make the framework effective.

A wrong: Structure without process integration is insufficient.

C wrong: Annual-only assessments miss emerging risks.

D wrong: Internal audit assesses risk management (Standard 2120).

Q40

Question: An auditor is testing the organization's compliance with data privacy regulations. The auditor finds that customer data is stored in a third-country data center without a legal transfer mechanism, and that data retention periods are not enforced. Management states that "the data center is secure" and that "retention is an IT issue." Which conclusion is MOST appropriate?

A. Compliance is adequate because the data center is secure.

B. Compliance is deficient; legal transfer mechanisms and retention enforcement are required regardless of security.

C. Data privacy is an IT issue, not an internal audit issue.

D. The auditor should ignore the findings because management disagrees.

Q40 – Answer & Explanation

Correct Answer: B

Why: Data privacy compliance requires lawful transfer mechanisms and retention enforcement. Security alone does not satisfy legal requirements.

A wrong: Security is not a legal transfer mechanism.

C wrong: Data privacy is a compliance/internal audit area.

D wrong: Management disagreement does not eliminate findings.

Q41

Question: The CAE is evaluating the organization's internal audit plan. The plan allocates 60% of resources to financial audits, 20% to compliance, and 20% to operational audits. The organization's risk profile shows significant IT/cybersecurity, strategic, and fraud risks that are not covered by the plan. Which action is MOST appropriate?

A. Keep the plan unchanged because financial audits are traditionally important.

B. Revise the plan to address significant IT/cybersecurity, strategic, and fraud risks, consistent with a risk-based approach.

C. Add all risks to the plan without adjusting resources.

D. Delegate IT and fraud coverage to the external auditor.

Q41 – Answer & Explanation

Correct Answer: B

Why: Standard 2010 requires a risk-based plan aligned with the organization's risk profile. Significant uncovered risks (IT, strategic, fraud) must be addressed.

A wrong: Tradition is not a risk-based rationale.

C wrong: Adding risks without resources is unrealistic.

D wrong: Internal audit retains responsibility for its plan.

Q42

Question: An auditor is assessing the organization's management override controls. The auditor finds that the CEO can post journal entries without review, can adjust system access rights, and can approve changes to the financial reporting system. Which conclusion is MOST appropriate?

A. Management override controls are effective because the CEO is trustworthy.

B. Management override controls are deficient; the CEO has excessive access and no independent review, creating a significant risk of undetected override.

C. Management override is not a risk because the CEO is accountable to the board.

D. The auditor should not assess management override.

Q42 – Answer & Explanation

Correct Answer: B

Why: Management override is a key fraud risk. Excessive CEO access without independent review significantly increases the risk of undetected override.

A wrong: Trust is not a control.

C wrong: Board accountability does not prevent override.

D wrong: Internal audit must assess override risk.

Q43

Question: The CAE is asked to assess the effectiveness of the organization's audit committee. The committee has three members, all former executives of the organization, meets twice a year, and has no explicit authority to hire or fire the CAE. Which conclusion is MOST appropriate?

A. The audit committee is effective because members have deep organizational knowledge.

B. The audit committee is likely ineffective; lack of independence, infrequent meetings, and no CAE authority impair oversight.

C. The audit committee is effective because it meets regularly.

D. Audit committee effectiveness is not an internal audit concern.

Q43 – Answer & Explanation

Correct Answer: B

Why: Audit committee effectiveness requires independence, frequent enough meetings, and authority over the CAE. Former executives lack independence; twice-yearly is likely insufficient.

A wrong: Organizational knowledge does not substitute for independence.

C wrong: Twice-yearly may be insufficient.

D wrong: Internal audit assesses governance (Standard 2110).

Q44

Question: An auditor is testing the organization's controls over the financial close process. The auditor finds that the controller prepares the consolidating entries, reviews them, and posts them, and that no one else reviews the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; the controller has incompatible duties (prepare, review, post) with no independent review.

C. Controls are effective because consolidating entries are routine.

D. The auditor should not assess the financial close process.

Q44 – Answer & Explanation

Correct Answer: B

Why: The controller prepares, reviews, and posts consolidation entries with no independent review, creating a significant segregation-of-duties deficiency.

A wrong: Experience is not a control.

C wrong: Routine entries can still be manipulated.

D wrong: Financial close is a core audit area.

Q45

Question: The CAE is evaluating whether the organization's internal audit activity is independent. The CAE reports functionally to the audit committee but administratively to the CFO; the audit committee approves the audit plan; the CFO approves the audit budget and HR decisions. Which statement is MOST accurate?

A. Independence is impaired because the CFO controls the budget and HR decisions.

B. Independence is supported by functional reporting to the audit committee; administrative reporting to the CFO is acceptable if it does not impair objectivity.

C. Independence is impaired because the audit committee approves the plan.

D. Independence is irrelevant for internal audit.

Q45 – Answer & Explanation

Correct Answer: B

Why: Functional reporting to the audit committee (plan, charter, reporting, CAE evaluation) supports independence. Administrative reporting to the CFO is common; independence is impaired only if the CFO can influence audit judgment.

A wrong: Administrative reporting alone does not automatically impair independence.

C wrong: Audit committee approval of the plan supports independence.

D wrong: Independence is essential.

Q46

Question: An auditor is evaluating the organization's risk culture. The auditor observes that employees are rewarded exclusively for meeting sales targets, that risk concerns are dismissed as "blocking progress," and that no one is held accountable for control failures. Which conclusion is MOST appropriate?

A. The risk culture is strong because sales targets are met.

B. The risk culture is weak; incentives, dismissal of risk concerns, and lack of accountability indicate a poor risk culture.

C. Risk culture cannot be assessed by internal audit.

D. The auditor should ignore culture and focus on controls.

Q46 – Answer & Explanation

Correct Answer: B

Why: Risk culture is reflected in incentives, openness to risk concerns, and accountability. These indicators point to a weak culture.

A wrong: Sales results do not equal strong risk culture.

C wrong: Internal audit assesses culture as part of governance/risk.

D wrong: Culture drives control effectiveness; it cannot be ignored.

Q47

Question: The CAE is assessing the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q47 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q48

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's brother owns a supplier that received $2 million in contracts last year, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the supplier is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they are family matters.

Q48 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's brother's company are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Family matters can be fraud indicators.

Q49

Question: The CAE is asked to evaluate the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q49 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q50

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q50 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q51

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q51 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q52

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q52 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q53

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q53 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q54

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q54 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q55

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q55 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q56

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q56 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q57

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q57 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q58

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q58 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q59

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q59 – Answer & Explanation

Correct Answer: B
Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.
A wrong: CIO accountability alone is insufficient.
C wrong: All projects require risk management.
D wrong: IT project risk is a core audit area.